

ThreatCraft: Automated Attack Scenario Generation via Hybrid Rule-Based and LLM-Driven Reasoning

Artifact Abstract

1 Paper title

ThreatCraft: Automated Attack Scenario Generation via Hybrid Rule-Based and LLM-Driven Reasoning.

2 Accepted Paper Link

<https://ase26-tools-datasets.hotcrp.com/doc/ase26-tools-datasets-paper39.pdf>

3 Purpose

This artifact provides ThreatCraft, a tool for automatically generating attack scenarios by considering causal relationships among threats and system components rather than merely identifying individual threats. It also includes all resources required to reproduce the results reported in the paper, including the source code, rule sets, LLM prompts, evaluation datasets, configuration files, and execution scripts.

4 Badges

We apply for the Artifacts Available, Artifacts Functional, and Artifacts Reusable badges.

- Artifacts Available: ThreatCraft is publicly available as a source-code artifact through the project repository. The repository includes the source code, example input files, threat libraries, example outputs, documentation, and license information required to inspect and evaluate the artifact.
- Artifacts Functional: ThreatCraft can be executed locally as a Python-based GUI application. The artifact provides the core functionality described in the paper, including DFD loading, rule-based attack path generation, attack graph rendering, and LLM-based attack scenario generation and refinement. The repository also provides example files that can be used to test whether the artifact runs correctly in the local environment.
- Artifacts Reusable: ThreatCraft is organized as a reusable software artifact. Its domain-specific threat libraries are structured under `code/backend/threat_library/`, where assets, threats, and related mappings for each domain are managed in a modular form. Users can update or extend the artifact by adding new assets, threats, or mappings to these library files. Because the threat libraries are written in widely used JSON formats, they can be easily inspected, modified, and reused without changing the core implementation. In addition, new domains can be supported by

adding or modifying the corresponding domain-specific library files. This structure allows ThreatCraft to be reused not only for the evaluation cases described in the paper, but also for additional systems, domains, and threat analysis scenarios.

5 Technology skills and Requirements

ThreatCraft is provided as a source-code artifact and runs as a Python-based GUI application in a local desktop environment.

- Hardware: No special hardware is required.
- Software: ThreatCraft requires Windows 10 or Windows 11, Python 3.10 or later, and Graphviz 14.1 or later. The required Python packages are graphviz and pillow.

6 Provenance

Zenodo: <https://doi.org/10.5281/zenodo.21154019>

The artifact can be downloaded from Zenodo using the link above. On the Zenodo record page, the artifact is provided as the file `heeyapro-ThreatCraft-newcraft.zip` in the Files section.

7 Instructions

Follow the steps below to set up and run ThreatCraft in a local Windows environment using Windows PowerShell. First, install Graphviz 14.1 or later from the official Graphviz website and add Graphviz to the system PATH. This step is required because ThreatCraft uses Graphviz to render attack graphs. After installing Graphviz, verify that it is accessible from Windows PowerShell:

```
dot -V
```

Next, install the required Python dependency packages in the project environment:

```
pip install graphviz==0.20.3 pillow==10.4.0
```

Then, navigate to the frontend directory and run ThreatCraft:

```
cd code/frontend  
python tool_attack_paths.py
```

However, if ThreatCraft cannot be executed properly due to software dependency or local environment configuration issues, it can also be executed using Docker. First, install WSL2 on Windows. Open Windows PowerShell as Administrator and run the following command:

```
wsl --install
```

After the WSL2 installation is complete, restart the system if required. Next, install Docker Desktop for Windows from the official Docker website:
<https://docs.docker.com/desktop/setup/install/windows-install/>

After installing Docker Desktop, launch Docker Desktop and keep it running. Then, open Windows PowerShell and move to the root directory of the extracted ThreatCraft artifact.

Build the Docker environment:

```
docker compose build
```

Run ThreatCraft in the Docker environment:

```
docker compose up -d
```

After the container starts successfully, open the following URL in a web browser:

<http://localhost:6080/vnc.html?autoconnect=1&resize=scale>

Once executed successfully, the ThreatCraft GUI will be displayed on the screen. After launching ThreatCraft, first select the target domain to be analyzed. For example, if the target scenario is a vehicle attack scenario, select the Automotive / Vehicle domain and click Start. Next, configure the analysis context in the GUI as follows.

- DFD File Selection: Load the target system model in TM7 format. (Example: /app/example/Automotive_DFD.tn7)
- LLM Configuration: Select the LLM backend and input a valid API key. (Example: GPT or Gemini) If an API key is unavailable, select Ollama to use the LLM-based features without requiring an API key.
- Target Definition: Select the target asset to be analyzed. (Example: Door)
- Trust Boundary Selection: Select the relevant system boundary. (Example: External Vehicle Boundary)
- Attack Mode: Select the attacker capability. (Example: Remote)
- Run Analysis: Click Run Analysis to start the attack scenario generation process.

All required threat intelligence libraries, including CVE/CWE/EMB3D mappings, dependency graphs, and risk models, are preloaded through the Library File Settings by default.

If CWE/CVE-level vulnerability mapping is required, implementation details can be configured for selected assets before generating the final results. For example, an asset such as a TCU can be configured with implementation characteristics such as a Linux operating system, loadable kernel modules, or Linux namespace isolation. This step is optional, and implementation details do not need to be provided for all assets. After the analysis settings and optional implementation details are configured, ThreatCraft generates the final analysis results. The generated results can also be saved or inspected through the report files produced by the tool.

Appendix

How to Copy and Paste an API Key in the Docker Environment

1) Click the arrow on the left side of the screen to open the toolbar. Then, click the **paste icon highlighted in red**.



2) In the clipboard window, press **Ctrl+V** to paste the API key. The API key shown in the figure is covered with a red box to prevent exposure.



3) Temporarily close the clipboard window, click the **AI API Key** input field, and then press **Ctrl+V** again to paste the API key.

